SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
Reg.no	192311129	**Name of the Student**	Narra Harshith

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I N.Harshith (192311129) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

N.Harshith

Signature of Student

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)

Introduction

Network attacks are malicious activities aimed at compromising the confidentiality, integrity, or availability of systems and networks. Common network attacks include malware, phishing, Denial of Service (DoS), and Distributed Denial of Service (DDoS).

1. Malware

Malware (Malicious Software) is software designed to damage, disrupt, or gain unauthorized access to systems.

Types of Malware:

- **Virus:** Attaches to files and spreads when executed.
- **Worm:** Self-replicates without user interaction.
- **Trojan Horse:** Disguises itself as legitimate software.
- **Ransomware:** Encrypts files and demands payment.
- **Spyware:** Secretly monitors user activities.

Example: WannaCry ransomware infected thousands of computers worldwide.

Preventive Measure: Install and regularly update antivirus software.

2. Phishing

Phishing is a social engineering attack where attackers send deceptive emails, messages, or websites to trick victims into revealing sensitive information.

Example: A fake banking email asking users to enter login credentials on a fraudulent website.

Preventive Measure: Conduct user awareness training and enable Multi-Factor Authentication (MFA).

3. Denial of Service (DoS)

A DoS attack attempts to make a system or service unavailable by overwhelming it with traffic from a single source.

Example: A single attacker sending thousands of connection requests to a web server.

Preventive Measure: Implement rate limiting and firewall rules.

4. Distributed Denial of Service (DDoS)

A DDoS attack is similar to a DoS attack but uses multiple compromised systems (botnets) to generate massive traffic.

Example: Mirai botnet attack against Dyn DNS services.

Preventive Measure: Use Content Delivery Networks (CDNs), DDoS protection services, and traffic-scrubbing solutions.

Difference Between DoS and DDoS

Feature	DoS	DDoS
Attack Source	Single System	Multiple Systems
Scale	Small	Large
Detection	Easier	Harder
Impact	Moderate	Severe

Conclusion

Organizations can reduce the risk of network attacks through security awareness, antivirus solutions, firewalls, and DDoS protection mechanisms.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)

Definition

A Man-in-the-Middle (MitM) attack occurs when an attacker secretly intercepts and may modify communications between two parties without their knowledge.

How It Works

1. A user attempts to communicate with a legitimate server.
2. The attacker positions themselves between the user and the server.
3. The attacker intercepts, monitors, or alters the exchanged data.
4. Both parties believe they are communicating directly with each other.

Techniques Used in MitM Attacks

1. ARP Poisoning

The attacker sends forged ARP messages on a local network, associating their MAC address with the gateway's IP address.

2. Rogue Wi-Fi Access Point

The attacker creates a fake wireless hotspot that appears legitimate. Users connect unknowingly, allowing traffic interception.

3. DNS Spoofing

The attacker alters DNS responses and redirects victims to malicious websites.

4. Session Hijacking

The attacker steals session cookies or tokens and impersonates authenticated users.

Countermeasures

- Use HTTPS and TLS encryption.
- Verify digital certificates.
- Enable HSTS (HTTP Strict Transport Security).
- Use VPNs on public networks.
- Implement Dynamic ARP Inspection (DAI).
- Avoid connecting to unknown Wi-Fi networks.

Conclusion

MitM attacks can compromise sensitive information, but strong encryption and secure networking practices significantly reduce the risk.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)

Comparison

Spoofing	Sniffing
Involves impersonating another entity.	Involves capturing network traffic.
Active attack.	Usually passive attack.
Used to deceive systems and users.	Used to monitor communications.
Changes packet information.	Observes packet contents.

Types of Spoofing

1. IP Spoofing

An attacker falsifies the source IP address of packets.

Example: Pretending to be a trusted server to bypass security controls.

2. MAC (ARP) Spoofing

The attacker modifies MAC address information to impersonate another device.

Example: Redirecting network traffic through the attacker's computer.

3. Email Spoofing

The sender address is forged to appear as a trusted individual or organization.

Example: An email pretending to be from a bank.

4. DNS Spoofing

The attacker manipulates DNS responses to redirect users to fraudulent websites.

Example: Redirecting victims from a real banking website to a fake one.

Sniffing

Sniffing is the process of capturing and analyzing network packets using tools such as:

- Wireshark
- tcpdump

Risks of Sniffing

Sensitive information such as usernames, passwords, and confidential data can be exposed if transmitted without encryption.

Detection and Prevention of Sniffing

- Use encryption protocols such as HTTPS, SSH, and VPNs.
- Deploy switched networks instead of hubs.
- Enable port security features.
- Monitor networks for interfaces operating in promiscuous mode.
- Use anti-spoofing and network access controls.

Conclusion

While spoofing focuses on impersonation, sniffing focuses on monitoring traffic. Strong encryption is the most effective defense against sniffing attacks.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)

Definition

A Vulnerability Assessment (VA) is the systematic process of identifying, evaluating, and prioritizing security weaknesses in systems, applications, and networks.

Steps in Vulnerability Assessment

1. Asset Identification

Identify all systems, servers, applications, and network devices that need assessment.

2. Vulnerability Scanning

Use tools such as:

- Nessus
- OpenVAS
- Qualys

to discover known vulnerabilities.

3. Analysis

Review findings and remove false positives.

4. Risk Rating

Assign severity levels using CVSS scores and business impact.

5. Reporting

Document vulnerabilities and provide recommendations.

6. Remediation and Verification

Apply security patches and verify that vulnerabilities have been fixed.

Contents of a Good Vulnerability Assessment Report
Executive Summary

Provides an overview of assessment findings.

Scope and Methodology

Details systems tested and assessment techniques used.

Vulnerability Findings

Includes:

- Vulnerability description
- CVE identifiers
- Evidence/screenshots
- Affected assets

Severity Ratings

Includes CVSS scores and risk levels.

Risk Impact

Explains potential business and technical consequences.

Prioritized Remediation

Lists recommended corrective actions in priority order.

Difference Between Vulnerability Assessment and Penetration Testing

Vulnerability Assessment	Penetration Testing
Identifies weaknesses	Actively exploits weaknesses
Broad coverage	Focused testing
Usually automated	More manual
Reports vulnerabilities	Demonstrates real impact

Conclusion

Vulnerability assessments help organizations proactively identify and remediate security weaknesses before attackers exploit them.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)

Definition

Open-Source Intelligence (OSINT) is the process of collecting, analyzing, and using information obtained from publicly available sources for security and intelligence purposes.

Common OSINT Sources

1. WHOIS Databases

Provide domain registration and ownership details.

2. Shodan

Search engine for internet-connected devices.

3. Social Media Platforms

Provide information about individuals, organizations, and ongoing events.

4. News Websites and Forums

Contain reports of cyber threats and security incidents.

5. Code Repositories

Platforms such as GitHub may reveal exposed credentials or security issues.

6. CVE and NVD Databases

Contain information about known vulnerabilities.

Other Threat Data Sources

Internal Sources

- Security logs
- SIEM alerts

- Honeypots
- Incident reports

Commercial Sources

- Vendor threat intelligence feeds
- Paid security research services

Open Sources

- Security blogs
- Research publications
- Public repositories

Techniques for Collecting Threat Data
Passive Collection

Gathering information without interacting with the target.

Web Scraping

Automated extraction of information from websites.

DNS and Domain Lookups

Collecting information about domains and network infrastructure.

Social Media Monitoring

Tracking threat actors and emerging threats.

Legal and Ethical Considerations

- Respect privacy laws.
- Obtain information only from authorized sources.
- Follow organizational policies and regulations.
- Avoid unauthorized access to systems.

Conclusion

OSINT is a valuable component of threat intelligence because it provides actionable information from publicly available sources while remaining cost-effective.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)

Definition

Indicators of Compromise (IoCs) are observable artifacts or evidence that indicate a system, network, or application may have been compromised by malicious activity.

Types of IoCs

1. File-Based IoCs

Indicators related to malicious files.

Examples:

- SHA-256 or MD5 file hashes
- Suspicious file names
- Modified system files

2. Network-Based IoCs

Indicators found in network traffic.

Examples:

- Malicious IP addresses
- Suspicious domains
- Known malicious URLs
- Unusual outbound traffic

3. Host-Based IoCs

Indicators present on endpoints.

Examples:

- Unauthorized registry keys
- Unknown processes
- Unexpected user accounts

Threat Feeds

A threat feed is a continuous stream of threat intelligence containing information about malicious activities, attackers, and IoCs.

Formats and Standards

- **STIX (Structured Threat Information eXpression)**
- **TAXII (Trusted Automated eXchange of Indicator Information)**

How Threat Feeds Improve Defense

1. Enable early detection of threats.
2. Automate SIEM correlation and alerting.
3. Support firewall and IDS/IPS blocking.
4. Improve threat hunting activities.
5. Speed up incident response.

Types of Threat Feeds

- Open-source feeds
- Commercial feeds
- Industry-specific feeds

Limitations

- False positives may occur.
- Data can become outdated quickly.
- Additional context is often required.
- Large amounts of data require filtering and analysis.

Conclusion

IoCs help security teams identify compromises quickly, while threat feeds provide continuously updated intelligence that strengthens organizational security defenses.